



FUNDAMENTALS OF INFORMATION SECURITY

SESSION 8

COURSE CODE:

CYBE 6123

LECTURER: **NGUEMETA NATHANIEL**



Malicious Software and Attack Vectors

Objective of the session

- What malware is and how it inflicts harm on an organization's systems
- What the main types of malware are
- What the history of malicious code is
- How malware is a threat to business organizations
- What motivates attackers and types of attacks
- What tools and techniques prevent attacks
- What tools and techniques detect attacks

Viruses



- An executable program that attaches itself to, or infects, other executable programs and then replicates to infect other programs.
- Some viruses also perform destructive activities after they replicate
 - Contains executable instructions on
 - Where to infect and replicate, called the *virus operational segment*
 - How to carry out its intent, called the *payload*
- Not all viruses carry a payload that inflicts harm
- Other viruses hide their payload and install a backdoor

Identifying the presence of Viruses

- Deteriorating workstation, server, or device responsiveness
- Unexpected and sustained disk activity levels (churning)
- Sudden sluggishness of user applications or services, particularly at startup
- Unexplained freezing of applications or unexpected error messages
- Unscheduled resets and crashes, including program aborts
- Sudden antivirus alarm activity
- Disk error messages, including increased “lost cluster” results from disk scanning
- Unexplained decrease in available space on disk or available memory
- In the case of macro viruses, saved documents that open as DOT files
- Applications (or their icons) that disappear or will not execute

Types of Viruses

- System infectors
 - Target computer and device hardware and software startup functions
- File infectors
 - Attack and modify executable programs (such as COM, EXE, SYS, and DLL files in Microsoft Windows)
- Data infectors
 - Attack document files containing embedded macro programming capabilities

System infector Viruses

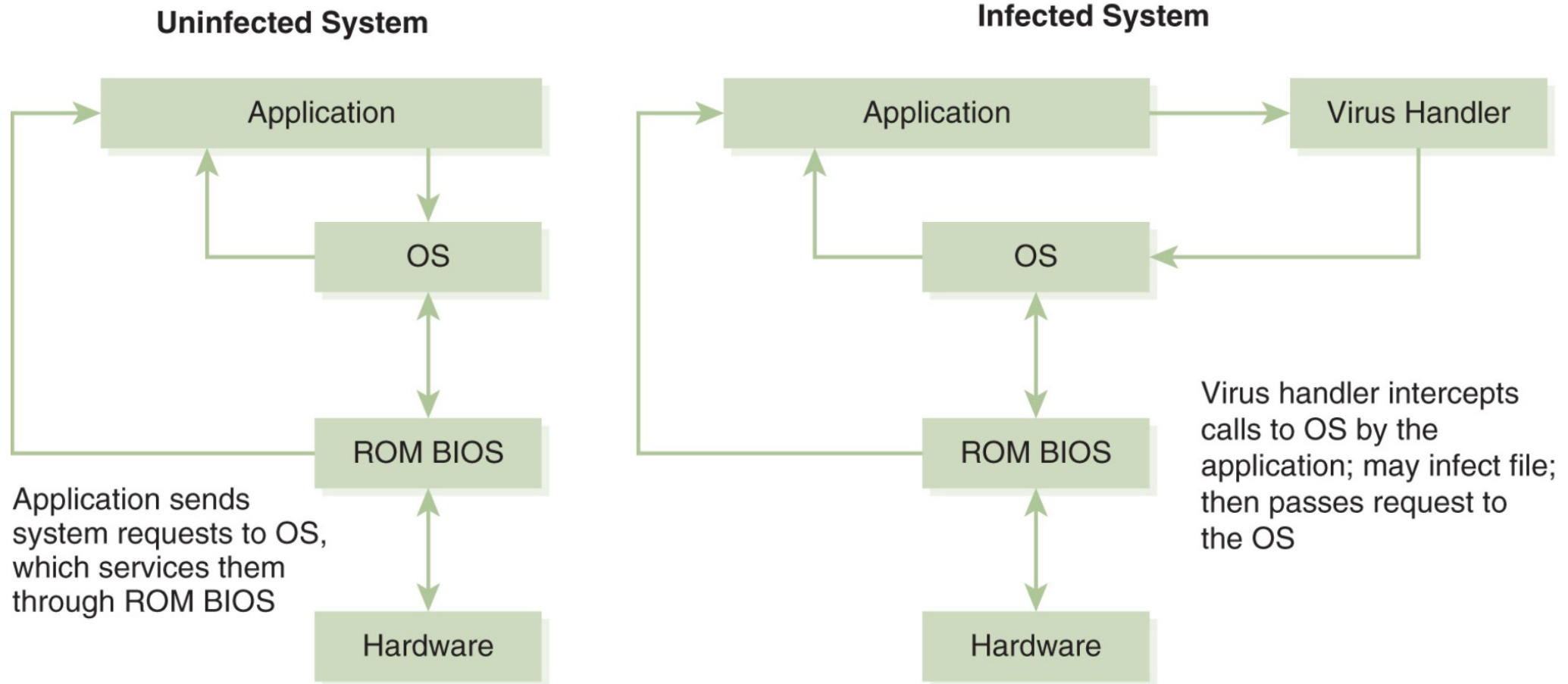


FIGURE 8-2 How a system infector virus works.

File infector Viruses

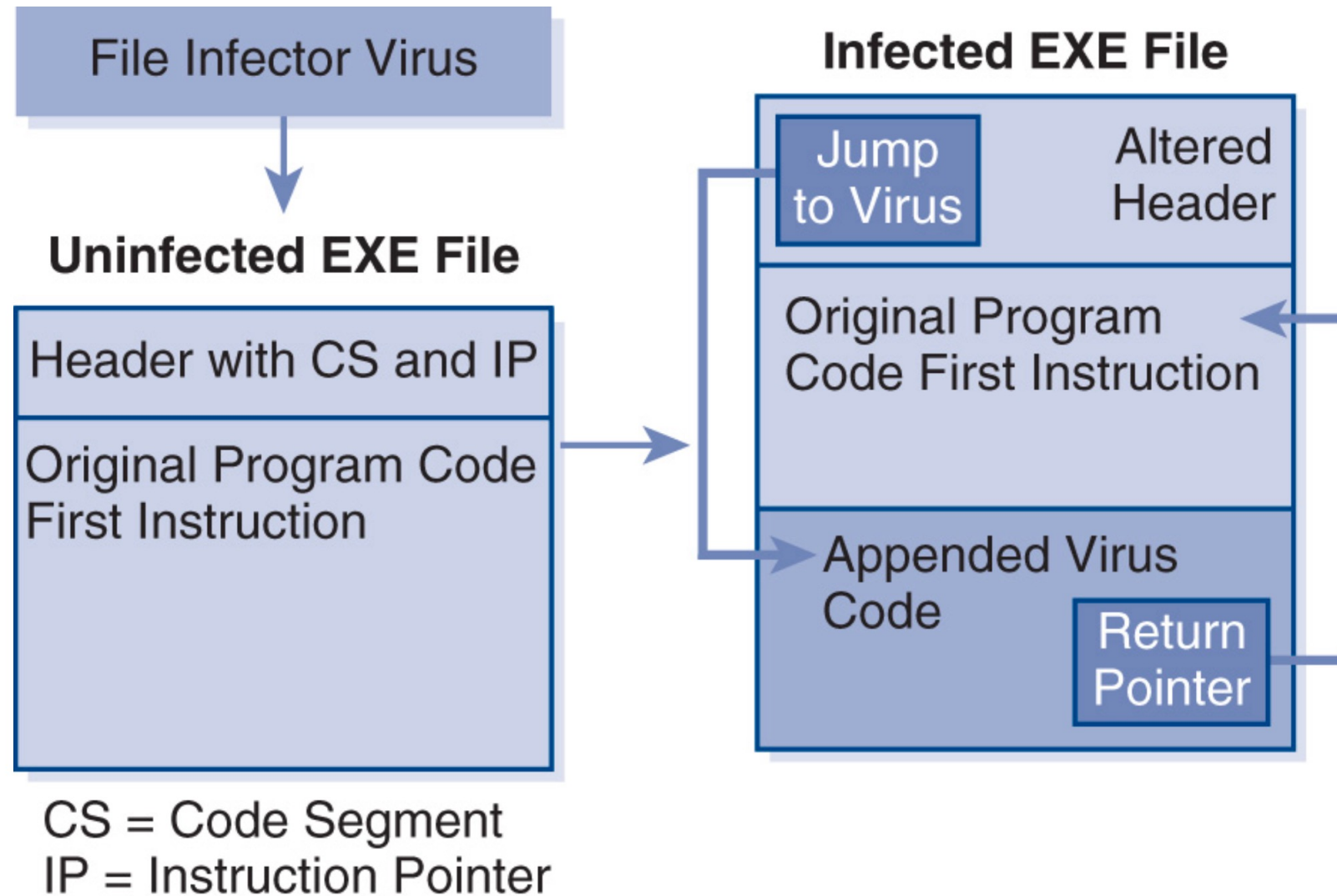


FIGURE 8-3 How a file infector virus works.

Macro (Data File) Infectors

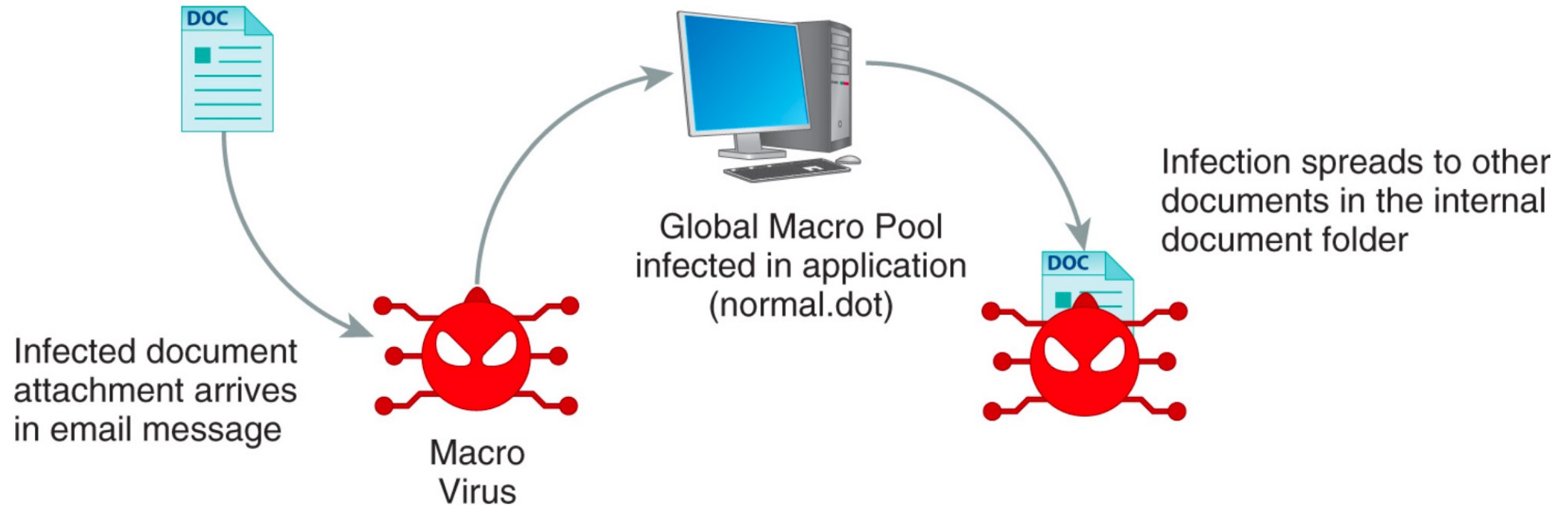


FIGURE 8-4 How a macro virus works.

Other Virus Classifications

- Polymorphic viruses
- Stealth viruses
- Slow viruses
- Retro viruses
- Cross-platform viruses
- Multipartite viruses
- Rootkits
- Ransomware
- Spam
- Worms
- Trojan Horses
- Logic Bombs
- Active Content Vulnerabilities
- Malicious Add-Ons
- Injections (XSS, SQL, LDAP, XML, Com)
- Botnets
- Spyware
- Adware
- Keystroke Loggers

Brief History of Viruses

- 1970s and Early 1980s: Academic Research and UNIX
 - Dr. Fred Cohen researched in 1983 and published in 1984
 - Robert Morris demonstrated in 1988 and created a worm that took over the network
- 1980s: Early PC Viruses
 - Brain (a boot sector virus), Lehigh, and Jerusalem (a file-infecting virus), Elk Cloner
- 1990s: Early LAN Viruses
 - Dark Avenger
- Mid-1990s: Smart Applications and the Internet
 - Melissa and Loveletter
 - Trojan programs, such as Back Orifice and AIDS
 - StrangeBrew (first virus to infect Java files)
 - WM/Concept7 (The first macro virus)

Malware Threats to Business Organizations (External)

- Attacks against confidentiality and privacy
- Attacks against data integrity
- Attacks against availability of services and resources
- Attacks against productivity and performance
- Attacks that create legal liability
- Attacks that damage reputation

Malware Threats to Business Organizations (Internal)

- The exchange of untrusted media among systems
- Installation of unauthorized, unregistered software (application and OS)
- Unmonitored download of files from the Internet
- Uncontrolled distribution of email, social media, or other messaging application attachments
- Unauthorized access to system and network resources
- Privilege escalation
- Theft, destruction, or unauthorized dissemination of data
- Use of corporate network resources to initiate hostile attacks against outside targets
- Accidental or intentional release of malicious code into internal network segments

Anatomy of an Attack



- What motivates attackers
- The purpose(s) of an attack
- Types of attacks
- Phases of an attack

Attack Motivation Factors

- Money
- Fame
- Imposition of their political beliefs or systems on others.
- Anger and Revenge
- State-level cyberwarfare or economic espionage.

Attack Purpose

- **Denial of availability**
 - DoS, DDoS, or Ransomware
- **Data modification**
 - Modify, delete, or overwrite it with new data
 - Modify system settings or browser security settings
- **Data export (exfiltration)**
 - Trojan horses forward usernames and passwords to an anonymous attacker's email
- **Launch point**
 - Botnet

Types of Attacks

- **Unstructured attacks**

- Moderate skills
- Low or unprecise Initial intentions
- Approach can become methodical
- Target may not be specific

- **Structured attacks**

- High motivation
- Technical skills
- Methodical and phased approach
- Specific target or profile

- **Direct attacks**

- Most often structured
- Intended results specified
- High determination
- Can be real-time

- **Indirect attacks**

- Can be wide-spread
- Usually done to dissuade from real target

Phases of an Attack

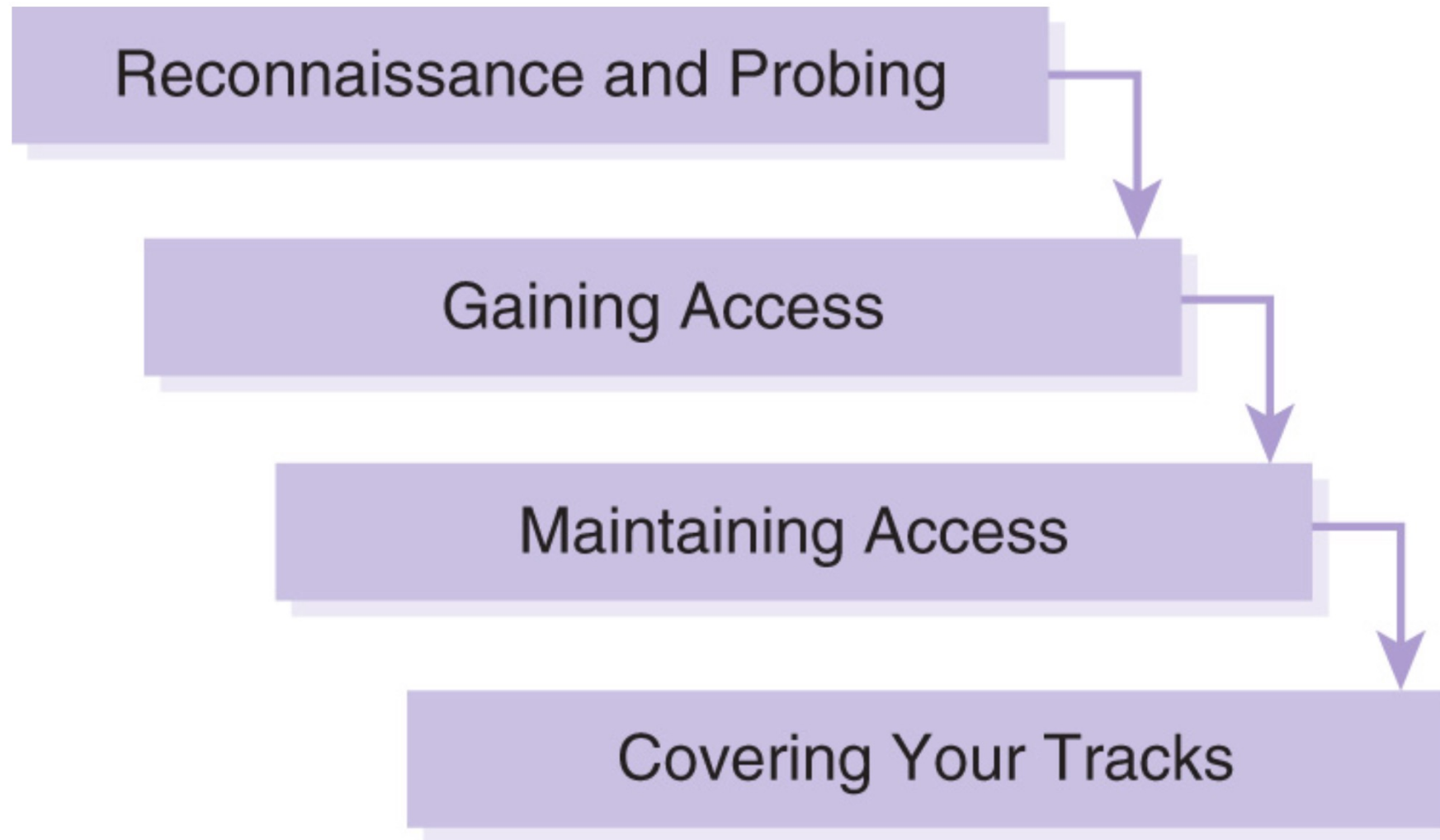


FIGURE 8-14 Phases of an attack.

Phases of an Attack



- **Reconnaissance and Probing**

- DNS and ICMP tools
- Standard and customized SNMP tools
- Port scanners and port mappers
- Security probes

- **Access and Privilege Escalation**

- Backdoor Sniffing like Trojan
- Password dictionaries or database
- Password crackers like L0phtCrack
- Credentials enumerators

- **Maintaining Access**

- Remote Access Tools (RAT)
 - Client and server version for remote control

- **Covering Traces of the Attack**

- Deletion of files created
- Deletion of log entries
- Service interruptions for diversion

Attack Prevention Tools and Techniques

- **Defense in depth**

- Application defenses
 - Operating system defenses
 - Network infrastructure defenses
- There should be layers of security and detection, even on single systems.
 - Attackers must break through or bypass each layer undetected.
 - Other layers can cover a flaw in one layer.
 - Overall system security becomes a set of layers within the overall network security.
 - Security improves by requiring the attacker to be perfect while ignorant.

Application Defenses

- Implementing regular antivirus screening on all host systems
- Ensuring that virus definition files are up to date
- Requiring scanning of all removable media
- Installing firewall and IDS software on hosts as an additional security layer
- Deploying change-detection software and integrity-checking software and maintaining logs
- Implementing email usage controls and ensuring that email attachments are scanned
- Enable pop-up blockers in web browsers to reduce exposure to accidental malware execution
- Establishing a clear policy regarding software installations and upgrades
- Ensuring that only trusted sources are used for installing, and upgrading software

Operating System Defenses

- Deploying change-detection and integrity-checking software and maintaining logs
- Deploying or enabling change-detection and integrity-checking software on all servers
- Ensuring that all operating systems are consistent and have been patched with the latest updates from vendors
- Ensuring that only trusted sources are used when installing and upgrading operating system code
- Disabling any unnecessary operating system services and processes that may pose a security vulnerability

Network Infrastructure Defenses



- Creating chokepoints in the network, and using content filtering at chokepoints to screen traffic
- Employing active sensors (e.g., intrusion detection and antivirus detection) that react quickly enough to prevent or mitigate damage
- Using proxy services and bastion hosts to protect critical services
- Ensuring that only trusted sources are used when installing and upgrading operating system code
- Disabling any unnecessary network services and processes that may pose a security vulnerability
- Maintaining up-to-date IDS signature databases
- Applying security patches to network devices to ensure protection against new threats and to reduce vulnerabilities

Safe Recovery Techniques and Practices

- Consider storing operating system and data file backup images on external media to ease recovering from potential malware infection.
- Scan new and replacement media for malware before reinstalling software.
- Disable network access to systems during restore procedures or upgrades until the protection software or services have been re-enabled or installed.

Intrusion Detection Tools and Techniques

- Antivirus Scanning Software
 - Kaspersky, Bitdefender, Symantec
- Network Monitors and Analyzers
 - Nessus or OpenVAS,
- Content/Context Filtering and Logging Software
 - Crowdstrike, Splunk (SIEM),
- Honeypots and Honeynets

Assignment

- List and describe 5 defense mechanisms against malware.
- Complete and submit assessment.



Thank You